Framework Implementation

Applying AI regulations and frameworks to a simulated company's AI systems (Fictional data).

Rebecca Froes
October 2026

This project turns AI governance into working artifacts: an inventory, scored risks, standards, a regulatory map, compliance evidence and tooling that flags problems automatically.

Contents

1. Scenario and approach
2. AI inventory and registry audit
3. AI risk register
4. AI Standards and Processes
5. Regulatory map
6. Compliance evidence log
7. AI incident handling
8. Governance tooling and automation

1. Scenario and Approach

DriveCo is a fictional company operating in Canada, the US and the EU. It runs seven AI systems: four built in-house and three supplied by vendors. The work follows one chain: register every system, score its risks, set standards that control those risks, map the standards to regulation, and keep evidence that the controls work.

2. AI inventory and registry audit

Every AI system is recorded before production use, including vendor-embedded AI and tools adopted informally. Unregistered AI is ungoverned AI. Each entry records owner, purpose, risk tier, training data lineage, personal data use, bias check, lawful basis, erasure impact, review dates and evidence.

ID	System	Build type	Risk tier	Audit result
AI 001	Vehicle Price Predictor	In-house	Minimal	Pass
AI 002	Customer Support Chatbot	Vendor	Limited	Pass
AI 003	Resume Screening Tool	Vendor	High	Review needed

AI 004	Fraud Detection Model	In-house	Minimal	Review needed
AI 005	Document Summariser (LLM)	Vendor	Limited	Review needed
AI 006	Vehicle Damage Image Assessment	In-house	Minimal	Pass
AI 007	Credit Pre-Qualification Model	In-house	High	Review needed

What the audit found:

- AI 003 (high risk): bias check blank, erasure impact blank and no evidence on file.
- AI 007 (high risk): bias check not done, no evidence on file and review overdue.
- AI 004: review overdue.
- AI 005: training data lineage not recorded.

Key finding: The two high-risk systems carry most of the gaps. Governance effort should go to the systems with the greatest impact on people, starting with hiring and credit.

3. AI risk register

One row per risk, each linked to a system in the registry. Risks are scored 1 to 5 for likelihood and impact (score = likelihood x impact) before and after controls. Rating: 15 or more High, 8 to 14 Medium, below 8 Low. Descriptions state the mechanism, not just the category.

System	Risk	Inherent	Residual	Rating
AI 001	Valuations drift as market prices shift faster than retraining; dealers overpay	9	6	Low
AI 002	Customers enter personal details; vendor keeps transcripts and may train on them	12	6	Low
AI 002	Chatbot gives wrong warranty or financing information	9	6	Low
AI 003	Vendor model reproduces historical hiring bias; candidates rejected without human review	20	16	High
AI 004	Fraud model flags some groups more often; legitimate transactions blocked	12	9	Medium
AI 005	Staff upload personal data; vendor lineage and data use undocumented	12	9	Medium
AI 006	Photos with faces or plates kept longer than needed	6	3	Low
AI 007	Credit features act as proxies for protected characteristics; unequal offer rates	15	12	Medium
AI 007	Erased customer data still reflected in trained model; no removal process	12	12	Medium

Key finding: The only risk still rated High after controls is the one whose key control, the bias examination, has no evidence yet. Controls that exist on paper but are not evidenced do not reduce risk, so the residual score stays high until the evidence is collected.

4. AI Standards and Processes

4.1 Acceptable use

- AI systems may only be used for purposes recorded in the registry. A new use case requires a registry update and a risk-tier review before launch.
- Staff must not enter confidential, personal or customer data into AI tools that have not been approved.
- Vendor-embedded AI features and informally adopted tools must be disclosed and registered before use.
- Users must be told when they are interacting with an AI system, for example a chatbot.
- AI output that affects a person (hiring, credit, claims) must be reviewed by a human before a decision is made.
- Staff who use or build AI receive AI literacy training appropriate to their role.

4.2 Model risk management

- Every system is assigned a risk tier at registration, using the EU AI Act categories as the reference. Systems used for employment or credit decisions are High by default.
- Risks are logged in the risk register with inherent and residual scores, named owners and linked controls.
- High-risk systems require a documented bias examination, event logging, a human oversight procedure and evidence on file before go-live.
- Review cadence: High every 6 months; Limited and Minimal every 12 months; risk register rows quarterly. Any significant change to a model, its data or its purpose triggers an out-of- cycle review.
- Solely automated decisions with legal or similarly significant effects on individuals require legal review.

4.3 Third-party AI vendor assessment

Before a vendor AI system is registered, the vendor must answer the following. Incomplete answers are recorded as risks.

1. What data was the model trained on, and can the vendor provide a lineage summary?
2. Is DriveCo data used to train or improve the vendor's models? Can this be switched off contractually?
3. Where is data stored and processed, and which sub-processors are involved?
4. How does the vendor test for bias and representativeness, and can it share the results?
5. How are deletion and erasure requests handled, including for data already used in training?
6. What security certifications or audits does the vendor hold?
7. How are model changes and incidents communicated to customers?
8. Which AI regulations does the vendor consider itself subject to, and how does it comply?

4.4 AI data governance

Concern	Control
Training data	Every system records its data sources and how they were prepared. Lineage gaps are

provenance and lineage	flagged in the audit. Vendor systems require a lineage summary.
PII in training and inference	The registry records whether personal data is used in training and in inference. Where it is, a lawful basis or consent record must exist. Prefer anonymised or minimised data where possible.
Bias and representativeness	High-risk systems must have a documented bias examination covering whether training data represents the people the system affects. Results are stored as evidence.
Consent management	Consent or another lawful basis is recorded per system. Where consent is the basis, withdrawal must be honoured in the data pipeline.
Right to erasure and trained models	Deleting a record from a dataset does not automatically remove its influence from a trained model. Each system documents its approach, such as scheduled retraining, vendor deletion commitments or technical unlearning where available, and the limits of that approach. Systems with no defined approach are flagged.

4.5 Regulatory tracking

- The regulatory map lists each requirement in plain language, the standard section that covers it and whether a gap is open.
- Each row is checked against the official source at least quarterly and the date is recorded. Fast-moving areas, such as the EU AI Act guidance and national implementation, are checked monthly.
- When a regulation changes, a draft update to the standards is prepared and sent to Legal and Engineering for review before approval.

4.6 Compliance evidence and audit

- Each control is linked to a requirement and has an owner, a piece of evidence and a status in the evidence log.
- Evidence must show the control working in practice, such as logs or test reports, not only a policy that says it should.
- The registry is audited monthly. Project teams register and maintain their own systems; the governance team checks them.

5. Regulatory map

Plain-language summaries written from general knowledge for this example. Each row should be verified against the official text before relying on it.

Ref	Source	Requirement	Gap open
R 01	EU AI Act, Art. 6 and Annex III	Systems used in areas such as employment and credit scoring are high-risk.	N
R 02	EU AI Act, Art. 10	Training and test data for high-risk systems must meet quality criteria, including examination for bias.	N
R 03	EU AI Act, Art. 12	High-risk systems must allow automatic recording of events (logs).	Y

R 04	EU AI Act, Art. 14	High-risk systems must allow effective human oversight.	Y
R 05	EU AI Act, Art. 50	People must be told when they interact with an AI system.	N
R 06	EU AI Act, Art. 4	Organisations should ensure sufficient AI literacy among staff.	Y
R 07	NIST AI RMF - Govern	Policies, accountability and culture for managing AI risk.	N
R 08	NIST AI RMF - Map, Measure, Manage	Identify context and risks, test and track them, then treat them.	N
R 09	ISO/IEC 42001 - data for AI manage systems	Controls for data quality, provenance and preparation.	N
R 10	ISO/IEC 42001 - third parties	Controls for suppliers providing AI components.	N
R 11	GDPR, Art. 17	Right to erasure; consider the effect on trained models.	Y
R 12	GDPR, Art. 22	Limits on solely automated decisions with significant effects.	Y
R 13	EU AI Act, Art. 9	High-risk systems need a continuous, documented risk management process.	N
R 14	GDPR, Art. 35	A data protection impact assessment is required before processing likely to be high risk to individuals..	Y

6. Compliance evidence log

Each control is tied to a requirement in the regulatory map. Three of nine controls have complete evidence (33%).

ID	Control	Req.	Owner	Status
C 01	Risk classification recorded for every system	R 01	AI Governance	Complete
C 02	Bias examination for high-risk systems	R 02	Data Science	Missing
C 03	Event logging enabled for high-risk systems	R 03	Engineering	In progress
C 04	Human oversight procedure approved	R 04	Risk	Missing
C 05	AI disclosure shown to chatbot users	R 05	Customer Experience	Complete
C 06	AI literacy training delivered	R 06	HR	Missing

C 07	Vendor assessments completed	R 10	Procurement	In progress
C 08	Erasure handling procedure for trained models	R 11	Privacy	In progress
C 09	AI Standards approved by management	R 07	Director, AI Governance	Complete

7. AI incident handling

An AI incident is any event where an AI system causes or contributes to harm, a policy breach, data exposure, a discriminatory outcome or a materially misleading output.

Level	Severity	Example
1	Low	Minor incorrect answer corrected by the user
2	Moderate	Repeated inaccurate outputs affecting a workflow
3	High	Sensitive data exposure or a harmful recommendation
4	Critical	Unauthorised high-impact action or legal exposure

1. Detect: user report, monitoring alert, audit finding or test result.
2. Triage: which system, whether personal data is involved, whether a person was affected, and whether the issue is recurring.
3. Contain: suspend the feature or output, switch to a human-only process, notify the owner.
4. Investigate and remediate: find the root cause, fix controls, retrain or reconfigure.
5. Report: record the incident, severity, cause, impact and owner. Escalate level 3 and above to the Director, AI Architecture & Governance.
6. Feed back: update the risk register, registry, standards and evidence log. A risk that materialised was not as unlikely as scored.

8. Governance tooling and automation

The workbook automates the checks a governance team would otherwise repeat by hand.

- Audit tab: flags blank registry fields, overdue reviews, high-risk systems without a bias check or evidence, personal data without a lawful basis, and systems with no risk entry.
- Risk register: calculates inherent and residual scores and ratings automatically.
- Dashboard: live counts of systems by tier, flagged systems, risks rated High, evidence completion rate and open regulatory gaps.
- The same logic could be configured in a GRC platform such as ServiceNow GRC, OneTrust or Collibra; Excel is used here to show the logic transparently